第4.2章 软件安全简介

- **学习要点：**
  - 了解软件安全的概念以及当前软件安全威胁的主要来源；
  - 熟悉软件安全风险分析的过程，特别是微软STRIDE威胁建模方法；
  - 了解安全软件开发生命周期的构成方式以及主要步骤；
  - 理解并掌握恶意软件的定义，特别是病毒，蠕虫和木马三者的机理与防治技术。

主要内容

1 传统软件开发生命周期

2 安全软件开发生命周期

3 其它安全软件开发生命周期模型

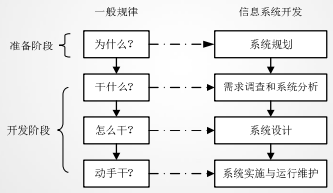
软件危机

- 从20世纪50年代末开始，计算机越来越普及，并广泛应用。可到了70年代初，出现了“软件危机”。什么是软件危机?
  - 危机主要表现为：软件成本超出预算，开发进度一再拖延，软件质量难以保证。
  - 原因在于：系统规模越来越大，复杂度也越来越高，用户需求不明确，缺乏正确的理论指导。
- “软件危机”使人们意识到信息系统的开发需要一套科学的、工程化的方法来指导，这就是常说的“系统分析与设计方法”。

系统工程思想及应用

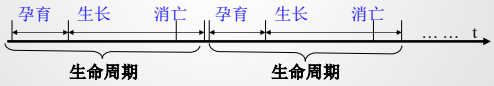
- 系统工程是一门用于大规模复杂系统设计的学问，是组织管理系统的规划、设计、制造、试验和使用的科学方法。
- 它的思想是以系统概念为基础的思想，表现为由粗到细、由表及里、由上到下、由整体到局部，逐步求精的分析。
- 系统工程方法一般步骤：调研→确定目标→确定功能→考虑方案（多个）→选择一个方案→实施→维护和评价。

信息系统开发的一般规律

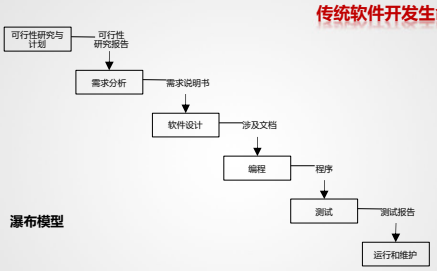


软件开发的生命周期

- 软件开发的生命周期（life cycle）：一个软件系统从它的提出、开发应用到系统的更新，经历一个孕育、生长到消亡的过程。这个过程周而复始，循环不息，每一次循环称为它的一个生命周期。生命周期的概念始于20世纪70年代。

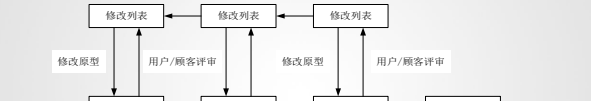


传统软件开发生命周期



瀑布模型

传统软件开发生命周期

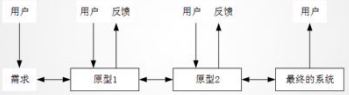


原型模型

传统软件开发生命周期

3. 渐进模型

- **目的**：和客户一起工作，从最初的大概的需求说明演化出最终的系统。抛出原型的目的是逐渐理解需求，没必要一次性完全理解需求，如下图所示。



渐进模型

- **存在的问题**：缺乏过程的可见性，系统通常不能够很好地结构化。渐进模型的一般应用在中小型规模的交互式系统或大型系统的一部分或生命周期较短的系统。

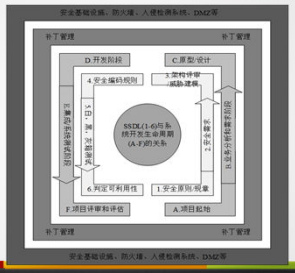
2 安全软件开发生命周期

2 安全软件开发生命周期

- **安全软件的开发生命周期(*SSDL*)**通过软件开发的各个步骤来确保软件的安全性，其目标是确保安全的软件得以成功实现。通常由5个主要部分组成。
  - **(1) 安全原则、规则及规章。**通常被视为保护性需求。该阶段应创建一份系统范围内的规范，在其中定义将应用到本系统的安全需求，此规范也可以通过特定的官方规章来定义。
  - **(2) 安全需求工程。**这里通常是特定功能需求所需的特有安全需求，这些安全需求有别于系统范围的安全要略和安全规范。同样，这种安全需求需要通过文档在项目起始的时候就定义下来。
  - **(3) 架构和设计评审、威胁建模。**软件的架构和设计应该被安全分析人员尽早评审，避免形成有安全缺陷的体系结构和设计。
  - **(4)软件安全编码。**需要代码的实现者对软件漏洞和软件安全编码原则有所了解。
  - **(5)软件安全测试。**包括白箱、黑箱、灰箱测试，软件渗透测试，基于风险的测试等等。

3 安全软件开发生命周期

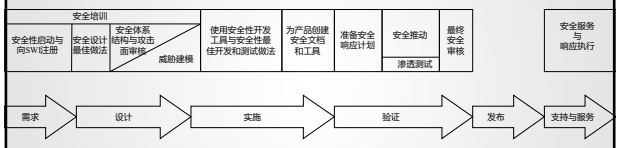
- SSDL与传统开发生命周期的关系，这里传统软件开发生命周期在SSDL的外面一层呈现。



传统软件开发生命周期与安全软件开发生命周期间的关系

安全软件开发生命周期

其它安全软件开发生命周期模型



Microsoft可信技术安全开发生命周期